

DRAFT — PRE-PRODUCTION REVIEW

AUDIENCE: CRYPTO & LEGAL REVIEWERS

BRIEF 26

REV AB28130

NO CODE SHIPPED

Zero-knowledge custody of survivor evidence

A design put before you so it can be challenged before it is built.
The goal: make “we cannot read your capture” *structurally true* rather than merely promised — without ever putting a survivor’s recording at risk to do it.

PARAMOUNT, ABOVE EVERY ENCRYPTION GOAL

Capture availability outranks capture confidentiality. A survivor mid-event still gets their recording — behind the flag, during migration, in every failure mode. If encryption and recording ever conflict, recording wins, and the pipeline **fails open** to today’s working upload rather than dropping a single

Recording what, and the pipeline runs open to today's working upload rather than cropping a single chunk.

§1 The custody model

Four parties, four distinct powers. The one line that must never blur: **operating ≠ releasing**. The organization's key *operates* a live response; only the survivor's authority *releases* evidence outward. Two powers, never one permission check.

PARTY	POWER HELD	NEVER
Survivor	Owens the capture. Holds a key, always. Releases it — the sole authority to send evidence outward.	—
Organization the org, not a person	Holds a key to operate — live-decrypt to run a response. Any authorized seat operates through the org key.	cannot independently distribute
Operator / server	Stores ciphertext, integrity hash, and wrapped keys. Nothing else.	never a readable key · never decrypts · no standing content access
Authorities / courts	Receive evidence only by survivor-authorized re-encryption, logged per instance.	never a standing copy

Why the org key, not a coordinator's. The responding coordinator is elected *after* an event begins, and the survivor may be incapacitated — access cannot be granted in the moment. So captures are encrypted to the organization; authorized seats operate through it, and offboarding revokes that access by rotation (state 8).

§2 The zero-knowledge boundary

The most important slide for a legal reader: what this design protects, and what it deliberately leaves readable. Overclaiming is a liability — so we claim only what is true.

ENCRYPTED — THE OPERATOR CANNOT READ

Content & place

Audio / video capture. Encrypted on-device before it leaves; the server stores opaque ciphertext it already never decodes.

Location — a later phase, wrapped to the org key so a coordinator can still operate it, never server-plaintext.

Contact graph — wrapped.

READABLE BY DESIGN — AND DISCLOSED AS SUCH

Timing & event state

That an alert happened, and when. Created / active / closed, heartbeat times, cascade step.

The operator reads these because **closure consent** and the **dark-and-unclaimed auto-close backstop** depend on them.

Hiding them would break the safety net that stops a survivor's event from hanging open. This is the boundary, not a leak.

Disclosure copy – say only what is true

*“BLACK BOX cannot read the content of your captures or your location — those are encrypted to keys we do not hold. BLACK BOX **can** see that an alert happened and when, because that is what lets an alert be closed and stops an event from hanging open. We track counts, not content.”*

§3 The custody flow, end to end

Nine states. This is a true sequence — a capture moves through it in order — so it is numbered as one. At every state the invariant holds: **no data key in clear, and no private key, exists on the server, ever.**

1 Created DEVICE ONLY

Capture produced on the device.

server holds: nothing yet

2 Sealed DEVICE ONLY

Encrypted on-device before it leaves, under a per-capture random data key.

encrypt-then-sign at upload

server holds: nothing yet

3 Wrapped

The data key is wrapped to the survivor's public key **and** the org's public key — never stored in clear.

wrap → survivor + org pub

4

Stored NOBODY SERVER-SIDE

Upload ciphertext + integrity hash + wrapped keys. The append-only signed hash chain covers the ciphertext unchanged.

server holds: ciphertext · hash · wrapped keys

5

Operated LIVE · THAT SEAT ONLY

The elected seat's client unwraps via the org key and decrypts each chunk to run the response — client-side, sub-millisecond, audit-logged.

client-side decrypt

audit: decrypt

6

Reviewed

Survivor or an authorized seat unwraps client-side to review. Same decrypt, logged.

survivor / authorized seat

audit: decrypt

7

Released TO A NAMED RECIPIENT

Survivor authorizes → the evidence is re-encrypted to the recipient's key → recorded as a logged key-provisioning event. Not a download-and-forward. No standing copy created.

re-encrypt to recipient

custody transfer + manifest

to encrypt to recipient

custody transfer + manifest

8

Revoked REQUIRED, NOT OPTIONAL

A seat is offboarded → the org keypair rotates → prior captures' keys are re-wrapped to the new org key. The departed seat's cached key opens nothing. A departed seat that keeps access is a failure.

org rotation → re-wrap

wired to Brief 24 offboarding

9

Deleted

Survivor deletes → ciphertext destroyed → hash + audit metadata retained per policy.

server holds: hash + audit metadata only

§4 Failure modes, ranked

A bug here has three severe outcomes. They are not equal — the ranking decides every trade-off in the build.

1 The survivor's evidence is lost forever

Availability failure — the highest severity, above confidentiality. A dropped capture, a lost key with no recovery, a migration bug on the capture path.

Guard — fail-open on capture · flag-gated · new-captures-only · test accounts first

2 The zero-knowledge claim is false

Confidentiality failure — a readable key reaches the server, a data key is stored in clear, a decrypt path exists server-side, or metadata leaks past the disclosed boundary.

Guard — “prove the server cannot decrypt” acceptance test · independent crypto review

3 A coordinator cannot decrypt to run a live response

Operability failure — the key isn’t delivered to the elected seat in time, or decrypt lags the response.

Guard — key-delivery at claim · client-side per-chunk decrypt · bounded latency

§5 Four decisions, resolved before build

Answered deliberately, and stated plainly to the survivor where a trade was made.

A · KEY LOSS

Org-enrolled: re-provision. Individual: recovery code only.

The org already holds an operating key, so re-provision costs no new custody. An individual who loses both the

B · METADATA SCOPE

Location → wrapped. Timing / state → clear.

Location is wrapped to the org key. Timing and event state stay operationally clear — closure and the auto-close backstop require them. This is the boundary, disclosed.

code to new custody. An individual who loses both the device and the code loses the capture — stated plainly at setup.

C · RETROACTIVE

New captures only.

Migrating existing captures puts risk on the most safety-critical path for little pilot-scale gain.

D · RELEASE AUTHORITY

Survivor only, per-instance delegation.

The survivor authorizes each release, with logged, revocable per-instance delegation to a named coordinator. No standing delegation.

§6 Where this review sits

Four hard gates precede production — not paperwork. This dossier is the input to gates two and three. **No production crypto is written until both of you sign off.**

1 Threat model written first

assets, adversaries, trust boundaries, ranked failures

DELIVERED

2 Independent crypto review

primitives + envelope design, before any production code

YOU ARE HERE

3 Legal review — chain of custody

is re-encrypted evidence admissible? perfect crypto $\neq$ admissible evidence

YOU ARE HERE

4 Flag-gated rollout

proven capture-path zero-regression, test accounts first

AFTER SIGN-OFF

§7 What you are asked to decide

The design proposes; you dispose. Nothing below is assumed settled

— these are the questions the build waits on.

FOR THE CRYPTO REVIEWER

Primitives & envelope

Ratify or override. No custom crypto — established, audited constructions only.

Q1 Ratify the primitive stack — the proposal is WebCrypto ECDH P-256 + AES-256-GCM, with libsodium X25519 sealed-box as the alternative.

Q2 Vet the org-key delivery to an elected seat at the coordinator-claim step — the crux of operability

FOR THE LEGAL REVIEWER

Chain of custody

Perfect crypto is moot for the courts lane if the custody process is not legally sound.

Q1 Is evidence re-encrypted to a recipient's key admissible? Does per-instance re-encryption preserve chain of custody?

Q2 Wiretap and one/two-party consent law as applied to encrypted capture.

without a server-readable key.	
Vet the org-key rotation and re-wrap for revocation (state 8): who re-wraps, and how it is made tamper-evident.	DPA alignment — with audit logs and per-seat watermarking as the “what a seat may do” layer, separate from what crypto controls.
Confirm per-chunk framing and IV handling, and the encrypt-then-sign ordering against the existing request HMAC.	Confirm the disclosure copy claims no more than is true about the timing/state boundary.

Deliverable Threat model + envelope design **Status** Draft — awaiting gates 2 & 3 **Revision** ab28130

Production crypto none written

This document is the input to the independent crypto review and the legal chain-of-custody review. On sign-off, the build begins as a flag-off, capture-path-zero-regression phase — chunk media first, where the server is already blind. The guided-intake tool does not begin until this is proven in production.